

Equipe de Resposta a Incidentes de Segurança – CSIRT

Objetivo da Aula

Compreender a necessidade de criação de uma equipe de CSIRT (Equipe de Resposta a Incidentes de Segurança), de forma a fortalecer sua postura de segurança, criando uma cultura proativa e resiliente diante dos desafios cibernéticos em constante mutação.

Apresentação

A equipe de Resposta a Incidentes de Segurança (CSIRT) desempenha um papel crucial na defesa contra ameaças cibernéticas, sendo responsável pela detecção, análise e resposta eficiente a incidentes em uma organização. Nesta aula, exploraremos a estrutura da equipe CSIRT, destacando os papéis específicos de seus membros.

Além disso, examinaremos o processo de resposta a incidentes, desde a detecção até a resolução, ressaltando a importância do treinamento contínuo e dos exercícios simulados para manter a equipe preparada para os desafios dinâmicos do cenário de segurança.

1. Equipe de Respostas a Incidentes

A equipe de Resposta a Incidentes de Segurança (CSIRT) desempenha um papel essencial na proteção e na resposta eficiente a incidentes de segurança em uma organização. Esta aula abordará a estrutura da equipe CSIRT, delineando os papéis e responsabilidades específicas de seus membros. Além disso, será detalhado o processo de resposta a incidentes, desde a detecção até a resolução, e a importância de treinamento contínuo e exercícios simulados para manter a equipe preparada para enfrentar desafios emergentes.

Figura 1: Site CERT.br



Fonte: CERT. Disponível em: <https://www.cert.br/csirts/>. Acesso em: 22 jan. 2024.

O Site CERT.br fornece material de apoio para as equipes de resposta a incidentes de segurança (Figura 1). Podemos conferir no site que o CERT.br desempenha o seguinte papel:

O Centro de Estudos, Resposta e Tratamento de Incidentes de Segurança no Brasil (CERT.br) é um Grupo de Resposta a Incidentes de Segurança (CSIRT) de Responsabilidade Nacional de último recurso, mantido pelo NIC.br. O NIC.br é uma entidade civil de direito privado e sem fins lucrativos, encarregada da operação do domínio.br, bem como da distribuição de números IP e do registro de Sistemas Autônomos no País. Conduz ações e projetos benéficos à infraestrutura da Internet no Brasil e implementa as decisões e os projetos do CGI.br, responsável por coordenar e integrar as iniciativas e serviços da Internet no país (CERT.br, 2024).

A estrutura da Equipe de Resposta a Incidentes de Segurança (CSIRT) é fundamental para a eficácia na detecção, análise e mitigação de incidentes de segurança cibernética. Cada membro desempenha um papel específico, garantindo uma abordagem abrangente e coordenada.

• **Líder da equipe (CSIRT manager):**

- Este papel é central na supervisão e coordenação das operações da equipe CSIRT. O **CSIRT manager** é responsável por definir estratégias, garantir a eficiência operacional e servir como ponto de contato principal com a liderança executiva da organização;
- Além disso, lidera o desenvolvimento de políticas de resposta a incidentes e coordena a colaboração entre os membros da equipe.

- **Analistas de incidentes:**

- Os analistas de incidentes formam a espinha dorsal da equipe, sendo responsáveis pela análise detalhada dos incidentes de segurança. Eles avaliam a gravidade, o impacto e a origem dos incidentes, utilizando ferramentas especializadas e técnicas forenses para compreender a natureza do ataque;
- A capacidade de identificar padrões, correlacionar dados e responder rapidamente é crucial para esses profissionais.

- **Especialistas em forense digital:**

- Focados na coleta, preservação e análise de evidências digitais, os especialistas em forense digital desempenham um papel crucial na investigação de incidentes. Eles utilizam técnicas forenses para reconstruir eventos, determinar a extensão do comprometimento e contribuir para a identificação dos atacantes;
- A habilidade de preservar a integridade das evidências é vital para futuras ações legais ou investigativas.

- **Comunicação e relações públicas:**

- Este papel é vital para a gestão eficaz da comunicação durante um incidente. Responsáveis por gerenciar a comunicação interna e externa, esses profissionais garantem a transparência nas informações divulgadas;
- Minimizar danos reputacionais e manter as partes interessadas informadas são metas centrais, requerendo habilidades de comunicação eficazes e o manejo de situações de crise.

- **Coordenador de recuperação:**

- Após a resolução do incidente, o coordenador de recuperação lidera os esforços para restaurar sistemas e dados afetados. Trabalhando em conjunto com a equipe de TI, eles desenvolvem e implementam planos de recuperação, garantindo que os sistemas voltem a um estado operacional normal;
- Este papel é muito importante para minimizar o tempo de inatividade e os impactos operacionais.

A colaboração eficaz entre esses membros da equipe CSIRT é essencial para uma resposta coesa a incidentes de segurança, garantindo que a organização possa enfrentar desafios cibernéticos de maneira robusta e eficiente.

2. Processo de Resposta a Incidentes

O processo de resposta a incidentes é uma abordagem estruturada e sequencial projetada para lidar de maneira eficaz com ameaças à segurança cibernética. Este processo compreende várias fases interconectadas, cada uma desempenhando um papel vital na gestão e resolução de incidentes.

A primeira fase do processo é a **detecção**, onde a equipe CSIRT identifica atividades suspeitas por meio de monitoramento contínuo e o uso de ferramentas especializadas de detecção de intrusões. Essa detecção pode ser baseada em anomalias de tráfego, alertas de sistemas de segurança ou indicadores de comprometimento.

Após a detecção, os analistas de incidentes entram em ação para realizar uma **análise aprofundada**. Essa fase envolve a avaliação da gravidade e do escopo do incidente, incluindo a determinação da origem e do impacto potencial. Os analistas utilizam técnicas forenses e ferramentas de análise para compreender a natureza do ataque.

Uma vez que o incidente é compreendido, a fase de **contenção** é iniciada. O objetivo é isolar o incidente para evitar sua propagação e minimizar danos adicionais. Isso pode envolver o isolamento de sistemas afetados, bloqueio de tráfego malicioso ou a implementação de medidas de segurança para conter a ameaça.

Vamos então para a fase de **erradicação**, que se concentra na remoção completa da ameaça do ambiente. Isso envolve abordar as causas fundamentais do incidente, corrigindo vulnerabilidades, removendo malware e garantindo que o ambiente de TI retorne a um estado seguro e controlado.

Após a erradicação, a equipe CSIRT trabalha em conjunto com a equipe de TI para iniciar a fase de **recuperação**. O objetivo é restaurar os sistemas e dados afetados para um estado operacional normal. Isso pode envolver a restauração de backups, a implementação de **patches** de segurança e a verificação completa da integridade do ambiente.

A última fase do processo é a **análise pós-incidente**, onde a equipe revisa e documenta as lições aprendidas. Esta análise inclui a revisão do desempenho da equipe, a eficácia das medidas tomadas durante o incidente e a identificação de melhorias nos processos de resposta a incidentes. Isso fortalece a postura de segurança da organização e contribui para uma abordagem proativa na prevenção de futuros incidentes.

A eficácia do processo de resposta a incidentes depende da rapidez e precisão com que cada fase é executada. Uma abordagem bem-sucedida não apenas restaura a normalidade operacional, mas também fortalece a resiliência da organização diante de ameaças futuras.

3. Treinamento e Exercícios

O treinamento contínuo e os exercícios simulados são pilares fundamentais para manter a equipe CSIRT (Equipe de Resposta a Incidentes de Segurança) preparada e eficaz diante das crescentes ameaças cibernéticas. Essas práticas não apenas aprimoram as habilidades individuais dos membros da equipe, mas também fortalecem a capacidade coletiva de resposta.

- **Treinamento técnico:**

- O desenvolvimento contínuo de habilidades técnicas é imperativo na área de segurança da informação. Os profissionais da CSIRT devem manter-se atualizados sobre as últimas técnicas de ataque, ferramentas de análise forense, e estratégias de mitigação. Cursos, workshops e certificações específicas são valiosos para aprimorar a expertise técnica da equipe.

- **Exercícios de simulação:**

- Os exercícios simulados são cenários controlados que reproduzem situações de incidentes reais. Realizar simulações regulares permite testar a prontidão da equipe em condições simuladas, identificar lacunas no processo de resposta e melhorar a coordenação entre os membros. Esses exercícios também proporcionam a oportunidade de avaliar a eficácia das políticas de segurança da organização.

- **Atualização de conhecimentos:**

- A paisagem de ameaças cibernéticas está em constante evolução. A equipe CSIRT deve acompanhar de perto as tendências em segurança da informação, participar de conferências, webinars e fóruns, e estar envolvida em comunidades de segurança. Isso garante que a equipe esteja ciente das últimas ameaças, vulnerabilidades e soluções emergentes.

- **Revisão pós-exercício:**

- Após cada exercício simulado, uma análise pós-exercício é essencial. Isso envolve uma avaliação crítica do desempenho da equipe durante o exercício. Identificar lições aprendidas, pontos fortes e áreas de melhoria é crucial para aprimorar os processos de resposta a incidentes. Essas revisões fornecem *insights* valiosos para ajustar políticas, procedimentos e estratégias de treinamento futuras.

- **Desenvolvimento de cenários realistas:**

- Os exercícios simulados devem ser baseados em cenários realistas e relevantes para o ambiente operacional da organização. Isso inclui simulações de ataques específicos, como *phishing*, *ransomware*, ou intrusões avançadas, proporcionando à equipe uma experiência prática na abordagem de ameaças específicas que podem enfrentar.

- **Colaboração com outras equipes:**

- A colaboração interdisciplinar é vital. Os exercícios podem envolver não apenas a equipe CSIRT, mas também outras equipes relevantes, como TI, comunicação corporativa e jurídico. Isso promove uma compreensão holística e coordenação eficaz durante incidentes reais.

Investir em treinamento contínuo e exercícios simulados não apenas aprimora a capacidade de resposta da equipe CSIRT, mas também contribui para uma cultura organizacional focada em segurança, permitindo que a organização enfrente desafios cibernéticos com resiliência e eficácia.

Considerações Finais da Aula

Em um ambiente digital em constante evolução, a eficácia da equipe CSIRT é essencial para a segurança organizacional. A estrutura bem definida, o processo de resposta a incidentes meticuloso e o compromisso com o treinamento contínuo garantem uma resposta ágil e eficiente a ameaças emergentes.

Ao investir em exercícios simulados realistas e na atualização constante de conhecimentos, a organização fortalece sua postura de segurança, criando uma cultura proativa e resiliente diante dos desafios cibernéticos em constante mutação.

Materiais Complementares

**Vídeo**

Tratamento de Incidentes de Segurança na Internet, explicado pelo NIC.br

2014, NIC.br.

Vídeo apresenta o tratamento de incidentes de segurança da internet.

Disponível em: <https://www.youtube.com/watch?app=desktop&v=flu6JPRHW04>. Acesso em: 2 fev. 2024.

 Artigo**CSIRTS**

2024, CERT.br

Apresenta material de apoio para os grupos e resposta a incidentes de segurança em computadores

Disponível em: <https://www.cert.br/csirts/>. Acesso em: 2 fev. 2024.

 Artigo**CSIRTS acadêmicos**

2024, RNP.

Apresenta os CSIRT acadêmicos.

Disponível em: <https://www.rnp.br/sistema-rnp/cais/csirts-academicos>. Acesso em: 2 fev. 2024.

Referências

Livro verde: segurança cibernética no Brasil. **IBICT**, 2010. Disponível em: https://livroaberto.ibict.br/simple-search?location=%2F&query=CSIRT&rpp=10&sort_by=score&order=desc. Acesso em: 14 ago. 2023.